CONTENT DISCOVERY

TryHackMe Learning & Practical Report

Prepared by: Sofia

Focus: Web Application Security / WAPT Foundations

Platform: TryHackMe

Room: Content Discovery

IqraSec Academy - WAPT Internship - Phase 1

1. Executive Summary

Content Discovery is about finding things on a website that are not linked or are not meant to be public. I used manual methods (robots.txt, sitemap.xml, favicon, headers), OSINT methods (Google dorks, Wappalyzer, Wayback Machine, S3 buckets) and automated tools for directories and virtual hosts.

2. Lab Information

Platform	TryHackMe
Room / Lab	Content Discovery
Primary Domain	Web Application Security
Purpose	Foundational WAPT practice
Completion	Completed - all room tasks finished
Link	https://tryhackme.com/room/contentdiscoveryx

3. Learning Objectives

- Find hidden files and pages manually.
- Identify the technology and framework used by a site.
- Use OSINT sources like Google dorks and the Wayback Machine.
- Brute-force directories and virtual hosts with automated tools.

4. Manual Discovery

I checked robots.txt and sitemap.xml, which sometimes list paths the owner does not want search engines to show. I identified the framework from the favicon and page, read the HTTP response headers to get the X-FLAG value, and followed the hint in the page source to the framework admin portal. The portal accepted the default credentials **admin / admin**, which is a real-world misconfiguration.

5. OSINT Methods

Google dorks such as site: limit results to one website. Wappalyzer is a browser extension that shows which technologies a site uses. The Wayback Machine (web.archive.org) keeps old copies of pages. Company S3 buckets use URLs in the form s3.amazonaws.com and can be public by mistake.

6. Automated Discovery

Wordlist-based tools request thousands of possible paths and show which ones exist. Using a directory scan I found a hidden directory and a development log file. With virtual host enumeration in Gobuster (and filtering by response size) I looked for other hosts on the same server that answer with status 200.

7. Evidence

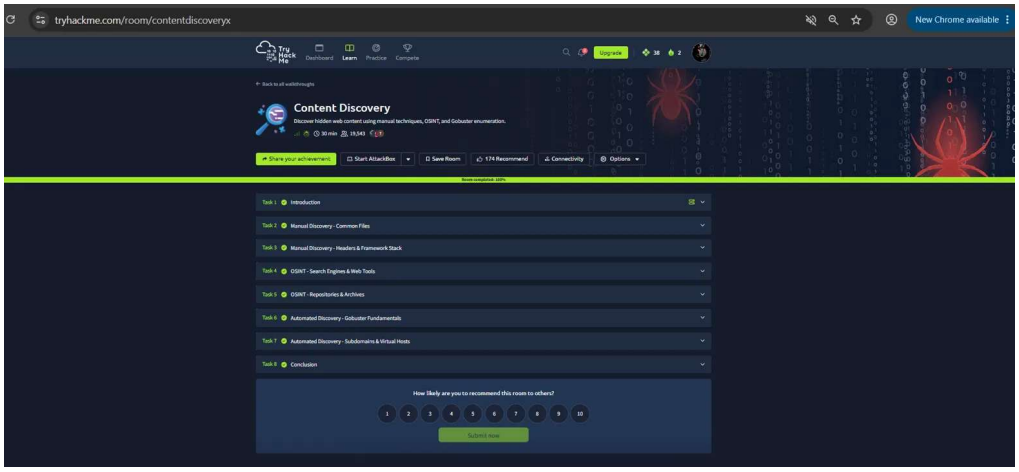


Fig 1 - Room overview.

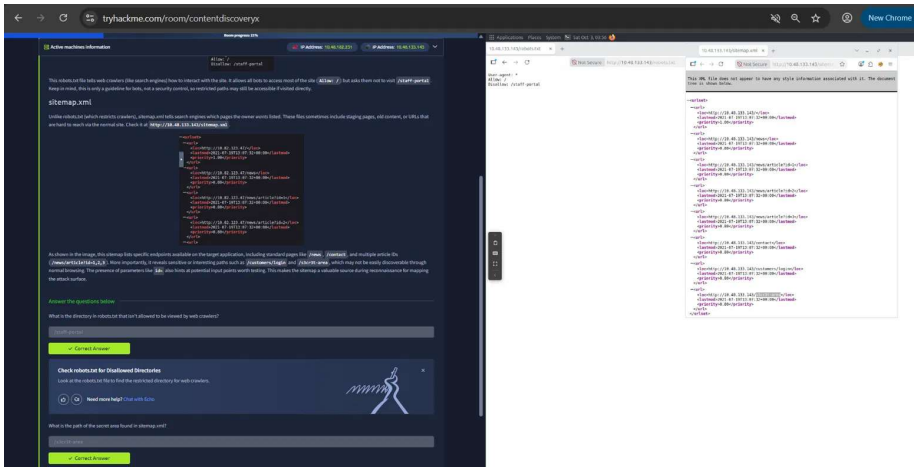


Fig 2 - robots.txt / sitemap content in the browser.



Fig 3 - X-FLAG header and admin portal questions.

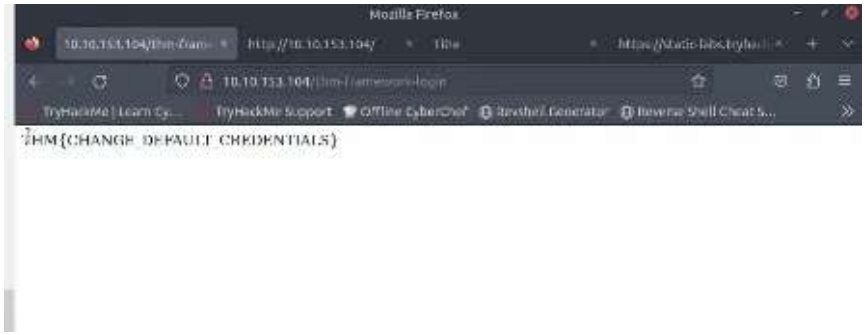


Fig 4 - Admin portal reached with default credentials.

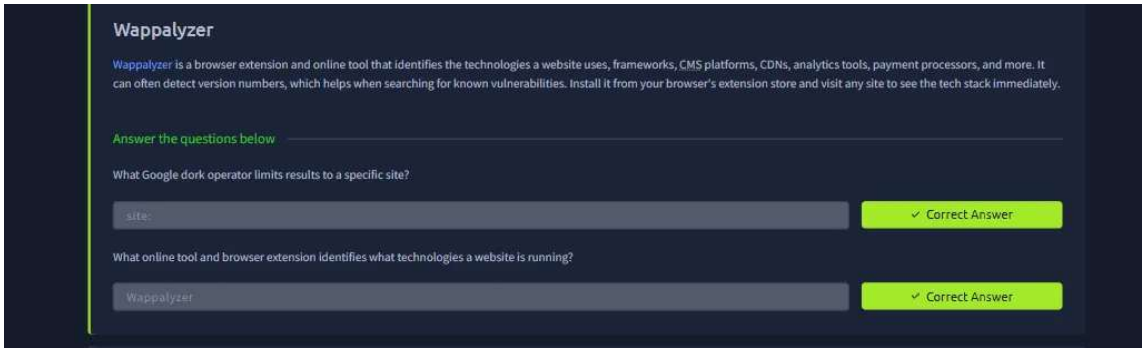


Fig 5 - Google dork and Wappalyzer questions.



Fig 6 - Wayback Machine and S3 URL format.



Fig 7 - Hidden directory and development log found.

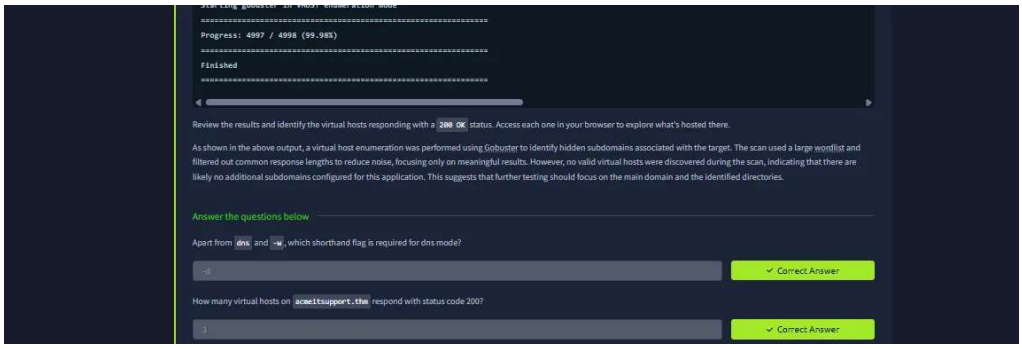


Fig 8 - Virtual host enumeration output.

8. Key Security Takeaways

- Forgotten files (logs, backups, admin pages) are common and dangerous findings.
- Default credentials must be changed on every system.
- Public archives and search engines can keep data that was removed from the site.
- Technology and version information helps an attacker pick known exploits.
-

9. Skills Practiced

Area	**Practical understanding gained**
Manual discovery	robots.txt, sitemap.xml, headers
Fingerprinting	Wappalyzer and framework detection
OSINT	Google dorks, Wayback Machine, S3 buckets
Brute force	Directory and virtual host enumeration

10. What I Would Explore Next

I will practise ffuf and gobuster more with different wordlists and combine them with Burp Suite.

11. Conclusion

This room showed me how much can be found just by looking in the right places. Hidden content and default passwords are often the easiest way into an application.

Completion status: Completed - all room tasks finished.

12. References

TryHackMe: https://tryhackme.com/room/contentdiscoveryx